

CISCO SECURE WORKLOAD

PCI DSS v4.0 Compliance Framework

Payment Card Industry Data Security Standard

Prepared for: [Customer Name]

Prepared by: Cisco Systems, Inc.

Date: [Month Year] | Version 1.0 | Cisco Confidential

Regulatory Standard: PCI DSS v4.0 (March 2022)

Environment: Hybrid (On-Premises + Cloud)

Deployment Stage: Fresh Installation

How to read the Coverage column

Direct means Secure Workload produces the primary evidence artifact for that row — segmentation, policy, flow and process telemetry, inventory, vulnerability and reachability, or forensic reconstruction. Direct is still evidence, not an attestation.

Supporting means Secure Workload contributes an input that feeds or complements another control, tool, or process — detection input only, reconciled against an external register, or one log source among several.

Evidence Required means Secure Workload has no record for that row. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

Every report in this set now uses the same three coverage words — Direct, Supporting, and Evidence Required. Coverage describes what evidence Secure Workload produces; it never means the control is passed.

Executive Summary

PCI DSS v4.0 introduces the Customized Approach and strengthens network segmentation requirements significantly. Cisco Secure Workload (CSW) directly satisfies Requirements 1 (Network Security Controls), 6 (Vulnerability Management), 7 (Access Control), 10 (Logging & Monitoring), and 11 (Security Testing) — the five requirements most commonly cited in PCI DSS audit findings.

CSW's workload-level micro-segmentation provides stronger CDE isolation than traditional firewall-only approaches, directly addressing QSA concerns about lateral movement within the cardholder data environment.

Control Coverage Summary

Req	Sub-Req	Control	PCI DSS Requirement	CSW Implementation	Coverage
Req 1	1.2.1	Network Control Config	Document and enforce network security controls	ADM generates complete approved flow documentation; policy workspace serves as config evidence	Direct
Req 1	1.3.1	Inbound CDE Traffic	Restrict inbound traffic to CDE to only what is necessary	Default-deny inbound to CDE scope; explicit allowlist only	Direct
Req 1	1.3.2	Outbound CDE Traffic	Restrict outbound traffic from CDE to only what is necessary	Block direct internet from CDE; allowlist-only outbound paths	Direct
Req 1	1.4.1	CDE Network Controls	Controls between CDE and untrusted networks	Workload-level micro-segmentation; enforced at OS — not just perimeter	Direct
Req 6	6.3.3	Vulnerability Remediation	Protect all system components from known vulnerabilities	Continuous CVE scanning; CVSS-ranked remediation; compensating controls	Direct
Req	7.2.1	Access	Restrict access to	Scope-based allowlist policies;	Direct

q 7		Restriction	system components and cardholder data	process-level access audit per workload	
Req 10	10.2.1	Audit Log Events	Capture required audit log events	Full 5-tuple flow + process + user context logging on all CDE workloads	Direct
Req 10	10.3.1	Audit Log Protection	Protect audit logs from destruction and unauthorized modification	Tamper-resistant cluster storage; export to immutable SIEM	Direct
Req 10	10.4.1	Audit Log Review	Review audit logs daily	Dashboard summary + automated alert export eliminates manual review burden	Direct
Req 11	11.3.1	Vulnerability Scans	Perform vulnerability scans at least quarterly	Continuous scanning exceeds quarterly requirement; reports serve as evidence	Direct
Req 11	11.4.1	Penetration Testing	Implement penetration testing methodology	ADM baseline used as pre/post-pentest reference; forensic telemetry captures all pentest activity	Supporting
Req 12	12.3.2	Targeted Risk Analysis	Conduct targeted risk analysis for customized implementations	CSW vulnerability + ADM data feeds targeted risk analysis documentation	Evidence Required

Cardholder Data Environment (CDE) Architecture

Recommended Scope Segmentation

CSW organizes workloads into scopes that directly map to PCI DSS network segmentation requirements:

CDE (Strictest)	CDE-Connected	Evidence Required	Third-Party Processors
PAN Storage Payment Processing Payment Gateways HSM Servers	Web Servers Auth Servers Logging Infrastructure	Corporate Systems Dev/Test Environments HR Systems	PCI-Compliant Vendors Acquirers Processing Networks
Default DENY all inbound Allowlist-only outbound Full forensic logging	Restricted to CDE-approved flows ADM-validated policies	Zero CDE communication ADM confirms isolation	BAA-documented paths Full flow audit per processor

QSA Evidence Package

Evidence Item	CSW Source	PCI Requirement	Frequency
CDE network policy export	Defend → Policy Workspaces	Req 1	Per assessment
CDE inbound/outbound flow log	Investigate → Flow Search	Req 1, Req 10	Continuous
Policy violation report	Alerts → Triggered Events	Req 10	Monthly
Vulnerability scan report (CDE)	Investigate → Vulnerability	Req 6, Req 11	Weekly
CDE scope membership snapshot	Inventory → Export	Req 1, Req 7	Monthly
Anomaly detection log	Alerts → Dashboard	Req 10, Req 11	Monthly
ADM dependency map (CDE)	Investigate → ADM	Req 1	Quarterly
Process audit log (CDE)	Investigate → Process Search	Req 10	On-demand